

RAPPORT — Points 1-5 Complétés

POINT 1 — Test Cross-École (C1)

Fichier : backend/tests/test_tenant_filter.py — 8 tests

Test	Vérification
test_admin_a_sees_only_school_a_courses	current_tenant_id.set(school_a.id) → db.query(contient PAS course_b1
test_admin_b_sees_only_school_b_courses	current_tenant_id.set(school_b.id) → ne contient PAS course_a1 ni course_a2
test_admin_a_does_not_see_school_b_users	current_tenant_id.set(school_a.id) → db.query(contient PAS admin_b@test.com
test_admin_b_does_not_see_school_a_users	Symétrie confirmée
test_super_admin_sees_all_courses	_tenant_filter_suppressed.set(True) → les 3 cours
test_super_admin_sees_all_users	Les 3 users visibles
test_pedagogical_admin_sees_all_courses	_tenant_filter_suppressed.set(True) → les 3 cours
test_no_tenant_sees_all	current_tenant_id.set(None) → les 3 cours visibles (sans filtre)

POINT 2 — Verrouillage de Compte (F3/F4)

Code implémenté

Fichier : backend/app/models.py:321-323 — Nouvelles colonnes User :

Account lockout (brute-force protection)

failed_login_attempts: Mapped[int] = mapped_column(Integer, default=0)

locked_until: Mapped[Optional[datetime]] = mapped_column(DateTime)

Fichier : backend/app/auth.py:240-260 — Logique de logout :

Account logout check (brute-force protection: 5 attempts → 15 min logout)

now = datetime.now(timezone.utc).replace(tzinfo=None)

if user.locked_until and user.locked_until > now:

 remaining = (user.locked_until - now).seconds // 60 + 1

 raise HTTPException(

 status_code=status.HTTP_423_LOCKED,

 detail=f"Account locked due to too many failed attempts. Try again in {remaining} min.",

)

if not verify_password(form_data.password, user.hashed_password):

 user.failed_login_attempts = (user.failed_login_attempts or 0) + 1

 if user.failed_login_attempts >= 5:

 user.locked_until = datetime.now(timezone.utc).replace(tzinfo=None) +
timedelta(minutes=15)

 user.failed_login_attempts = 0

 log_security_event("account_locked", {"user_id": user.id, "email": user.email},
severity="WARNING")

 db.commit()

...

Successful login — reset logout state

user.failed_login_attempts = 0

user.locked_until = None

Paramètres

Paramètre	Valeur
Tentatives avant lockout	5
Durée de lockout	15 minutes
Reset après succès	Oui (failed_login_attempts=0, locked_until=None)
Code HTTP	423 LOCKED
Cache des infos	Non — après 5 échecs, le compteur est remis à 0 (lockout activé)

Tests

Fichier : backend/tests/test_account_lockout.py — 5 tests

Test	Vérification
test_lockout_after_5_failed_attempts	5 mauvais mots de passe → 6e tentative (bon mot de passe) retourne 423
test_successful_login_resets_counter	4 échecs + 1 succès → compteur=0, locked_until=None
test_lockout_auto_expires	lockout dans le passé → login réussi
test_inactive_user_gets_403	is_active=False → 403
test_inactive_user_wrong_password_gets_401	Mauvais mot de passe sur compte inactif → 401 (pas de fuite d'info)

Résultat : 5/5 PASSED

POINT 3 — Classification require_admin → Migration M4

Voici la classification de TOUS les 124 usages de require_admin dans les routers. Validation requise avant migration.

Fichier : backend/app/routers/admin.py (~60 usages)

Endpoint	Ligne	Intention réelle	Helper recommandé
create_school	74	N'importe quel admin	require_admin (tel quel)
list_schools	98	N'importe quel admin	require_admin
get_school	115	N'importe quel admin	require_admin
update_school	124	N'importe quel admin	require_admin
list_users	148	N'importe quel admin	require_admin
get_user	203	N'importe quel admin	require_admin
user_update_post	221	N'importe quel admin	require_admin
reset_user_password	249	N'importe quel admin	require_admin
create_user	275	N'importe quel admin	require_admin
list_classes	328	N'importe quel admin	require_admin
create_class	340	N'importe quel admin	require_admin
enroll_student	355	N'importe quel admin	require_admin
list_enrollments	377	N'importe quel admin	require_admin

Endpoint	Ligne	Intention réelle	Helper recommandé
analytics_overview	389	N'importe quel admin (déjà filtré par school)	require_admin
user_analytics	431	N'importe quel admin (déjà filtré par school)	require_admin
list_users_detail	469	N'importe quel admin	require_admin
update_user	495	N'importe quel admin	require_admin
update_user_balance	557	Plateforme uniquement (solde)	require_platform_admin
toggle_user_active	574	Plateforme uniquement	require_platform_admin
change_user_role	599	Plateforme uniquement	require_platform_admin
approve_user	640	Plateforme uniquement	require_platform_admin
create_transaction	658	Plateforme uniquement	require_platform_admin
list_token_packages	693	N'importe quel admin	require_admin
create_token_package	702	Plateforme uniquement	require_platform_admin
update_token_package	711	Plateforme uniquement	require_platform_admin
dashboard_stats	724	N'importe quel admin (déjà filtré)	require_admin
list_messages	779	N'importe quel admin	require_admin

Endpoint	Ligne	Intention réelle	Helper recommandé
create_message	811	N'importe quel admin	require_admin
delete_message	849	N'importe quel admin	require_admin
broadcast_message	875	Plateforme uniquement	require_platform_admin
list_settings	906	Plateforme uniquement	require_platform_admin
update_setting	930	Plateforme uniquement	require_platform_admin
apply_settings	1019	Plateforme uniquement	require_platform_admin
test_ai_provider	1094	Plateforme uniquement	require_platform_admin
update_token_limits	1120	Plateforme uniquement	require_platform_admin
get_token_limits	1131	N'importe quel admin	require_admin
refresh_settings_cache	1142	Plateforme uniquement	require_platform_admin
list_wallets	1164	N'importe quel admin (déjà filtré)	require_admin
add_to_wallet	1239	Plateforme uniquement	require_platform_admin
deduct_from_wallet	1311	Plateforme uniquement	require_platform_admin
global_stats	1383	Plateforme uniquement	require_platform_admin
delete_user	1468	Plateforme uniquement	require_platform_admin

Endpoint	Ligne	Intention réelle	Helper recommandé
list_transactions	1501	N'importe quel admin (déjà filtré)	require_admin
revenue_analytics	1563	Plateforme uniquement	require_platform_admin
enrollment_trends	1669	N'importe quel admin (déjà filtré)	require_admin
api_cost_trends	1712	N'importe quel admin (déjà filtré)	require_admin
list_teacher_registrations	1767	Plateforme uniquement	require_platform_admin
review_teacher_registration	1797	Plateforme uniquement	require_platform_admin
duplicate_trial_content	1843	Plateforme uniquement	require_platform_admin
delete_school	1988	Plateforme uniquement	require_platform_admin
course_analytics	2002	N'importe quel admin (déjà filtré)	require_admin
list_audit_logs	2044	N'importe quel admin (déjà filtré)	require_admin
allocate_credits	2151	Plateforme uniquement	require_platform_admin
consumption_report	2189	Plateforme uniquement	require_platform_admin
purchase_school_pack	2305	École uniquement	require_school_admin

Endpoint	Ligne	Intention réelle	Helper recommandé
list_active_school_packs	2418	École uniquement	require_school_admin
pack_revenue_report	2481	Plateforme uniquement	require_platform_admin
import_students_from_csv	2569	École uniquement	require_school_admin
import_students_upload	2653	École uniquement	require_school_admin

Fichier : backend/app/routers/admin_courses.py (~19 usages)

Endpoint	Ligne	Intention réelle	Helper recommandé
list_courses	236	N'importe quel admin	require_admin
get_course	261	N'importe quel admin	require_admin
create_course	271	N'importe quel admin	require_admin
update_course	303	N'importe quel admin	require_admin
delete_course	329	N'importe quel admin	require_admin
bulk_update_courses	346	N'importe quel admin	require_admin
submit_for_review	371	N'importe quel admin	require_admin
unpublish_course	390	N'importe quel admin	require_admin
archive_course	407	N'importe quel admin	require_admin

Endpoint	Ligne	Intention réelle	Helper recommandé
duplicate_course	424	N'importe quel admin	require_admin
reorder_courses	501	N'importe quel admin	require_admin
preview_course	521	N'importe quel admin	require_admin
course_analytics	588	N'importe quel admin	require_admin
list_chapters	637	N'importe quel admin	require_admin
create_chapter	649	N'importe quel admin	require_admin
get_chapter	674	N'importe quel admin	require_admin
update_chapter	688	N'importe quel admin	require_admin
delete_chapter	710	N'importe quel admin	require_admin

Fichiers secondaires

Fichier	Usages	Recommandation
admin_chapters.py (7)	CRUD chapters	require_admin (tel quel)
admin_lessons.py (7)	CRUD lessons	require_admin (tel quel)
admin_quizzes.py (11)	CRUD quizzes	require_admin (tel quel)
ai_factory.py (10)	AI content generation	Plateforme uniquement → require_platform_admin

Fichier	Usages	Recommandation
media.py (5)	Media upload/serve	N'importe quel admin → require_admin
logs.py (2)	Audit/error logs	N'importe quel admin (déjà filtré) → require_admin
users.py (1)	_require_admin local	require_admin (tel quel)

Résumé de la migration proposée

Helper	Endpoints concernés	Nombre
require_admin (gardé tel quel)	CRUD cours/chapters/lessons/quizzes, analytics scolaires, users, classes, enrollments, media, logs, wallets	~70
require_platform_admin	Settings, token packages, broadcast, teacher registrations, delete user/school, revenue, credits, AI factory	~30
require_school_admin	purchase_school_pack, list_active_school_packs, import_students	~5

⚠ Validation requise : est-ce que cette classification te convient avant que je migre ?

POINT 5 — Audit Exhaustif Raw SQL

Résultat de `grep db.execute(text(` dans `backend/app/`

33 occurrences trouvées, réparties comme suit :

A. `backend/app/seeds.py` — 30 occurrences (script d'initialisation, pas de endpoint HTTP)

Lignes	Type	Données scolaires ?	Filtre school_id ?
30-293	CREATE TABLE / INSERT / SELECT COUNT	Non (DDL + seed)	N/A

Verdict : Pas de risque — script d'initialisation exécuté une seule fois, pas un endpoint HTTP.

B. backend/app/routers/admin.py — 3 occurrences

Ligne	Endpoint	SQL	Données scolaires ?	Filtre school_id ?
1191-1200	list_wallets	SELECT user_id, COALESCE(SUM(...)) FROM transactions WHERE user_id = ANY(:ids)	Oui (transactions)	Oui — les :ids viennent d'une requête ORM préalablement filtrée par school_id via _super_or_school_fi
1683-1692	enrollment_trends	SELECT DATE(created_at), COUNT(*) FROM users WHERE ...	Oui (users)	Oui — school_filter ajouté manuellement (fix M6/M
1726-1738	api_cost_trends	SELECT DATE(created_at), SUM(amount) FROM transactions WHERE ...	Oui (transactions)	Oui — school_filter ajouté manuellement (fix M6/M

C. backend/app/routers/ — 0 autres occurrences

Aucun autre router n'utilise de raw SQL.

D. backend/app/services/ — 0 occurrences

Aucun service n'utilise de raw SQL.

E. backend/app/tasks/ — 0 occurrences

Aucune tâche n'utilise de raw SQL.

Conclusion : Tous les raw SQL manipulant des données scolaires ont un filtre school_id manuel. Le seul risque résiduel est si un futur développeur ajoute du raw SQL sans filtre — le filtre ORM ne le couvrira pas.

Résumé final de la session

Point	Statut	Preuve
1. Test cross-école (C1)	✅ 8/8 tests PASSED	test_tenant_filter.py
2. Verrouillage compte (F3/F4)	✅ 5/5 tests PASSED	test_account_lockout.py + fix timezone
3. Classification M4	✅ 124 endpoints classifiés	En attente de validation
4. Tests M1 (is_active)	✅ 2/2 tests PASSED	Dans test_account_lockout.py
5. Audit raw SQL	✅ 33 occurrences, 3 scolaires, toutes filtrées	Rapport ci-dessus

58/58 tests passent. Tout est pushé sur phase1-critical.